

CHAPTER 3: IDENTIFICATION AND AUTHENTICATION

Le Thi Bao Thu

Faculty of Computer Science & Engineering

HCMC University of Technology

thule@hcmut.edu.vn

Outline

1 Introduction

2 Methods for Identification

3 Methods for Authentication

4 Protocols for Authentication

Introduction - Steps in Access Control

Identification

User provides his/her identity



Authentication:

The user proves that the identity is valid



Authorization:

What privileges and authorizations the user has

Introduction - Identification

- ❑ The user provides his/her identity for the system.
- ❑ Purposes: to find out whether the user exists and what privileges the user has.



Introduction - Authentication

- ❑ The user provides evidence to prove that the identity is right and suitable for user.
- ❑ Purposes
 - To prove the identity is valid and appropriate for the user.
 - To decide whether the user is allowed to access the resources of the system or not.



Outline

-
- 1 Introduction
 - 2 Methods for Identification**
 - 3 Methods for Authentication
 - 4 Protocols for Authentication

Methods for Identification

- ❑ There are 2 methods for identification:
 - The user input his/her identity by himself/herself.
 - Use digitizing identities:
 - biometric identity
 - computer identity
 - digital identity

Methods for Identification - Method 1

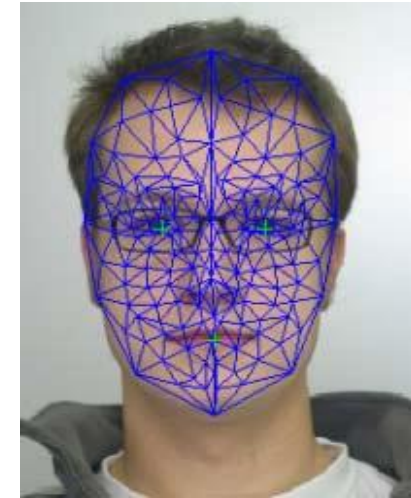
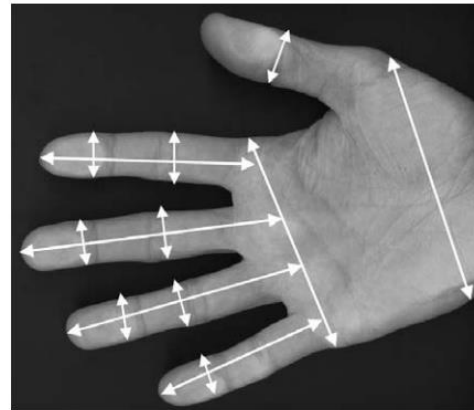
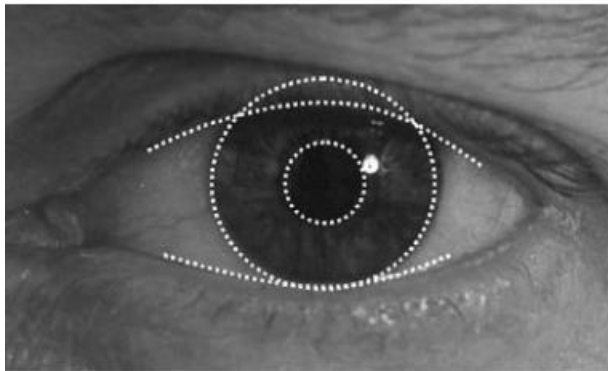
- ❑ **Method 1: The user input his/her identity by himself/herself.**
 - The most popular method nowadays.
 - E.g.: username, account number,...
 - The first step when a hacker wants to intrude into a system is collecting the list of valid users of this system.

Methods for Identification - Method 2

❑ Method 2: Use digitizing identities

❑ Biometric identity

- Facial recognition
- Iris scanners
- Hand geometry
- Fingerprint



Methods for Identification - Method 2

- ❑ **Method 2: Use digitizing identities**
- ❑ Computer identity
 - Computer name
 - MAC address
 - IP address

Methods for Identification - Method 2

- ❑ **Method 2: Use digitizing identities**
- ❑ Digital identity
 - Digital certificate
 - Smart card



Outline

-
- 1 Introduction
 - 2 Methods for Identification
 - 3 Methods for Authentication**
 - 4 Protocols for Authentication

Methods for Authentication

- ❑ Based on any combination of the following:
 - Something you know
 - Something you have
 - Something you are
- ❑ A good authentication method should not be guessed easily or faked.

Something you know

- ❑ E.g.:
 - Password
 - PIN (Personal Identification Number)
- ❑ Advantage:
 - Low cost
- ❑ Disadvantage:
 - The security degree

Something you know

❑ Password Issues:

- Password strength is not strong enough
→ Password policy
- Easy for user to remember but difficult for others to guess
- Social engineering
- Keystroke logging software and similar Spyware
- Password cracking tools

STRONG PASSWORD

Checklist

- ✓ **Make it long** (15+ characters)
- ✓ **Mix it up** (letters - capital & lowercase, numbers, and symbols)
- ✓ **Avoid Common Keyboard Paths** (don't use 1234 or asdfg)
- ✓ **Avoid Simple Substitutions** (don't use SL33P)
- ✓ **Don't Use Dictionary Words** (don't use words like cat or tinycat)

@lightboxsystems

Something you have

- ❑ Smart card (or other hardware tokens):
 - smartcard is a credit card sized device
 - includes a small amount of memory and computing resources
 - store cryptographic keys or other secrets
 - perhaps even do some computations on the card



Something you are

- ❑ Biometrics: “you are your key”
 - Facial recognition
 - Iris scanners
 - Hand geometry
 - Fingerprint
- ❑ An ideal biometric:
 - Universal
 - Distinguishing
 - Permanent
 - Collectable
 - Reliable, robust, and user-friendly

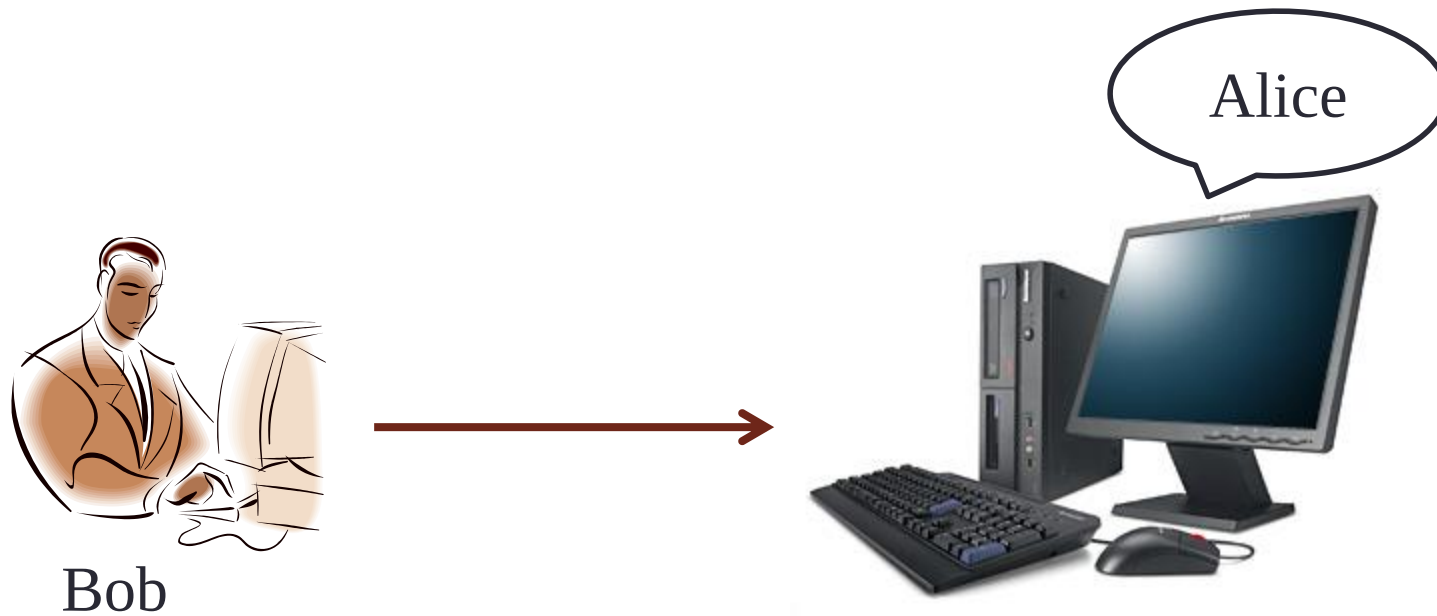
Something you are

❑ Two phases in a biometric system:

- Enrollment phase: subjects have their biometric information gathered and entered into a database.
- Recognition phase: the biometric detection system is used in practice to determine whether (for the authentication problem) to authenticate the user or not.

Something you are

- ❑ Types of Errors:
 - False accept rate (FAR)



Something you are

- ❑ Types of Errors:
 - False Reject Rate (FRR)



Something you are

❑ Types of Errors:

- Equal Error Rate: FAR = FRR

❑ Advantage:

- Difficult, although not impossible, to forge

❑ Disadvantage:

- Cost: biometric software, devices, programmers, server and other relative equipment

Isolated schemes

	EER (%)	
Geometry	0.20	
PalmPrint	0.29	
FingerPrint	0.17	
Vein	1.79	

Score Fusion Level

	EER (%)	
Geometry+Palm	0.09	
Geometry+Palm+Finger	0.04	
Geometry+Palm+Finger+Vein	<0.01	

Decision Fusion Level

	FAR (%)	FRR (%)
Geometry+Palm	0.20	<0.01
Geometry+Palm+Finger	<0.01	<0.01
Geometry+Palm+Finger+Vein	<0.01	<0.01

Ferrer, Miguel A., et al. "Combining hand biometric traits for personal identification." *43rd Annual 2009 International Carnahan Conference on Security Technology*. IEEE, 2009.

Methods for Authentication

- ❑ Balancing Security and Cost
- ❑ In security:
 - Biometrics > Smartcard > Password
- ❑ In cost:
 - Password < Smartcard < Biometrics
- ❑ Multi-Factor Authentication: homework

Outline

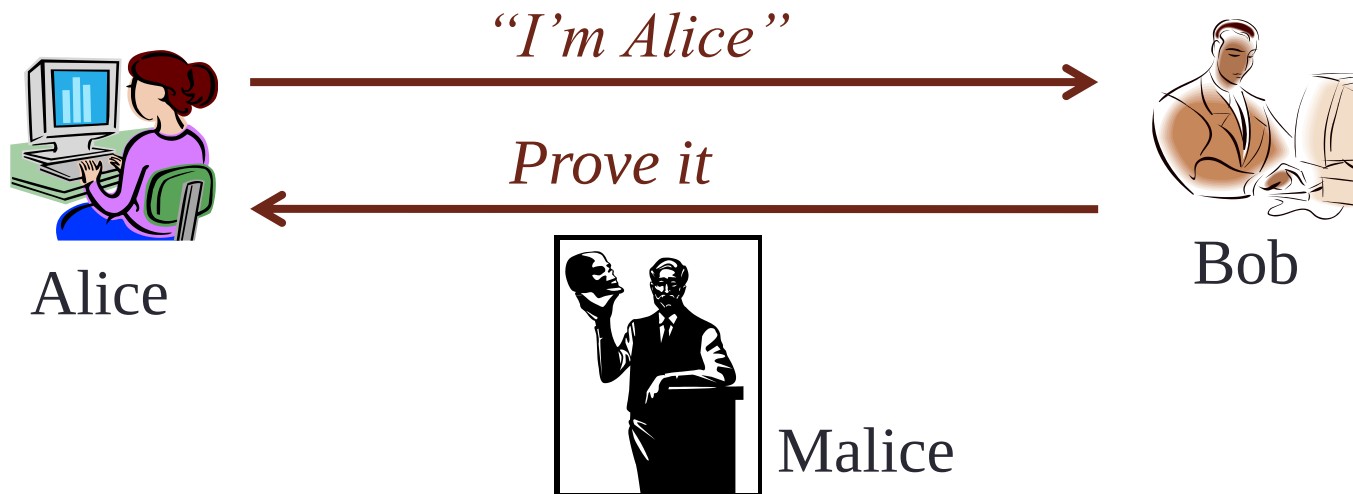
-
- 1 Introduction
 - 2 Methods for Identification
 - 3 Methods for Authentication
 - 4 **Protocols for Authentication**

Protocols for Authentication

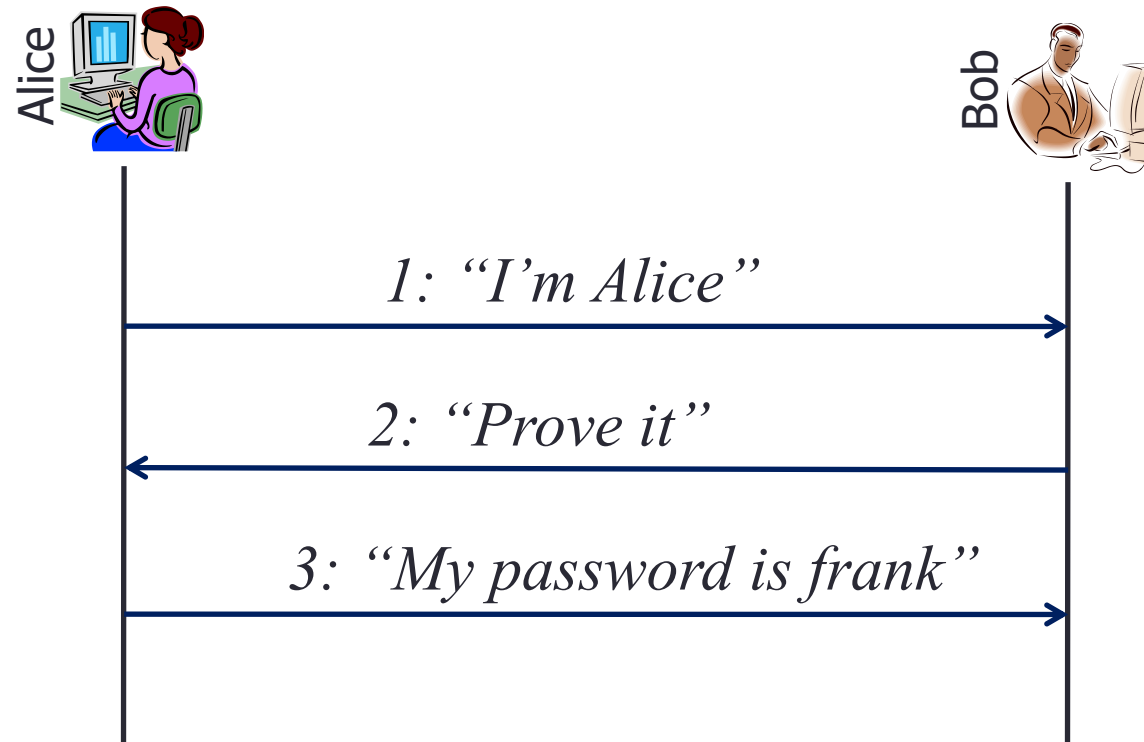
- ❑ **Simple security authentication protocol**
- ❑ Challenge-response authentication protocol
- ❑ Symmetric keys authentication protocol
- ❑ Public keys authentication protocol
- ❑ Kerberos authentication protocol

Simple security authentication protocol - introduction

- ❑ Alice must prove to Bob that she's Alice.
 - Alice and Bob are communicating over a network
- ❑ Bob must also prove his identity to Alice.
- ❑ **Malice:** a bad guy (or attacker, adversary, etc)

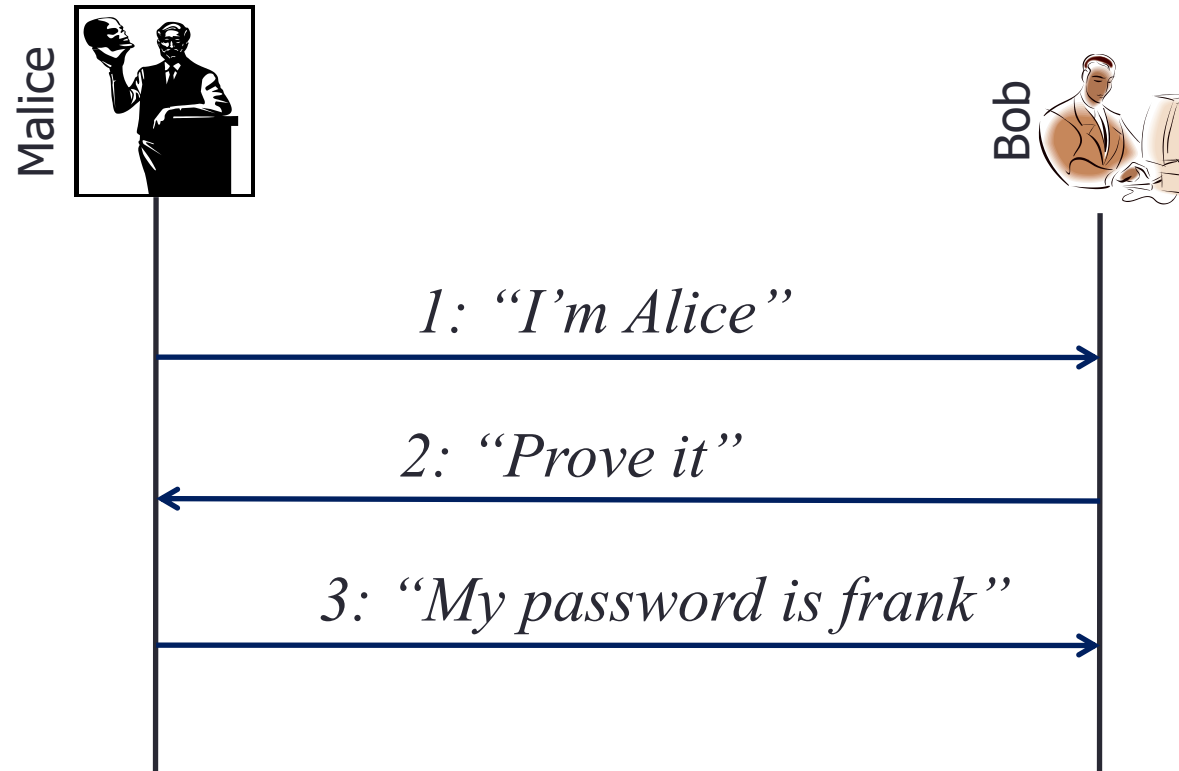


Simple security authentication protocol



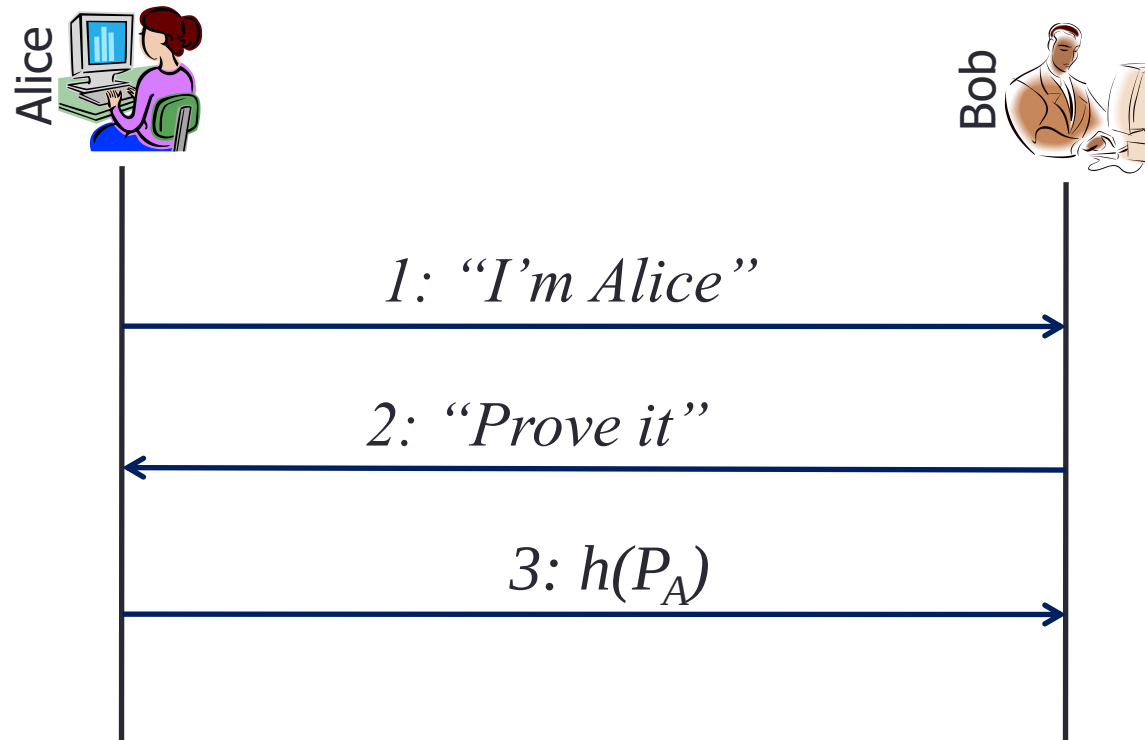
Simple security authentication protocol

- ❑ Alice's password is sent in the clear.



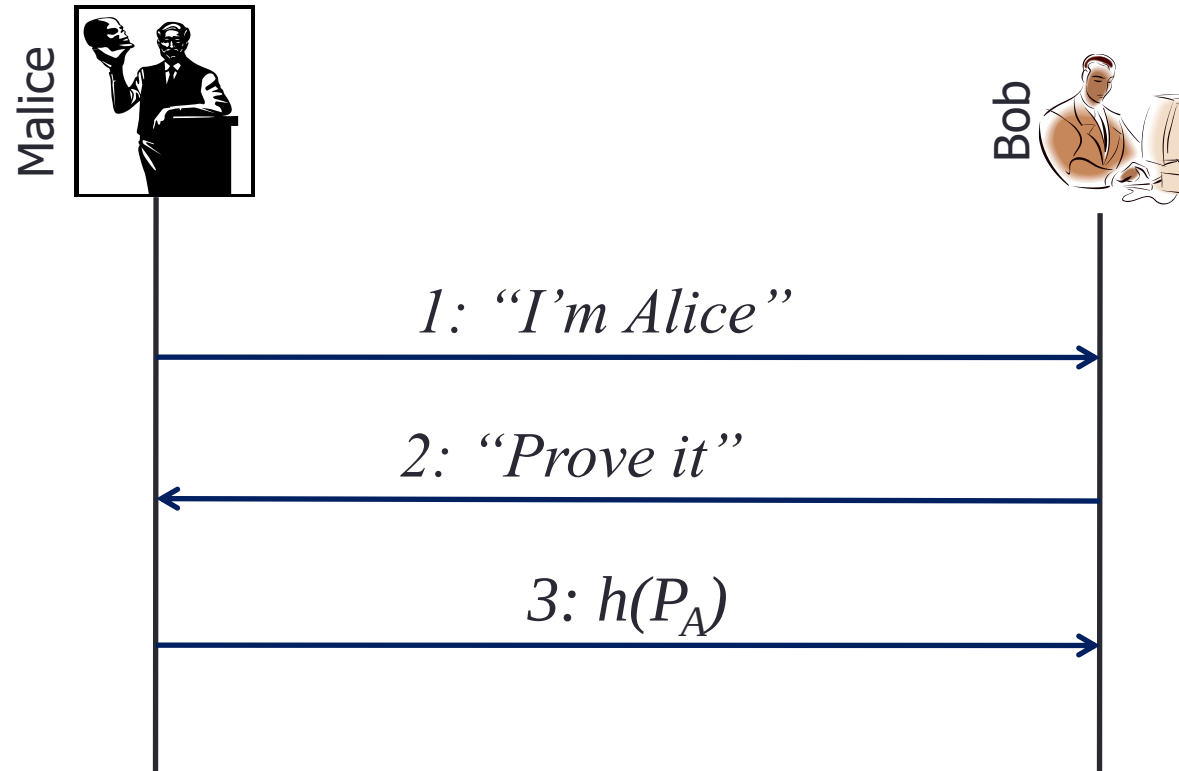
Simple security authentication protocol with hashing

- ❑ P_A : Alice's password
- ❑ $h()$: hash function



Simple security authentication protocol with hashing

- ❑ It's subject to a replay attack

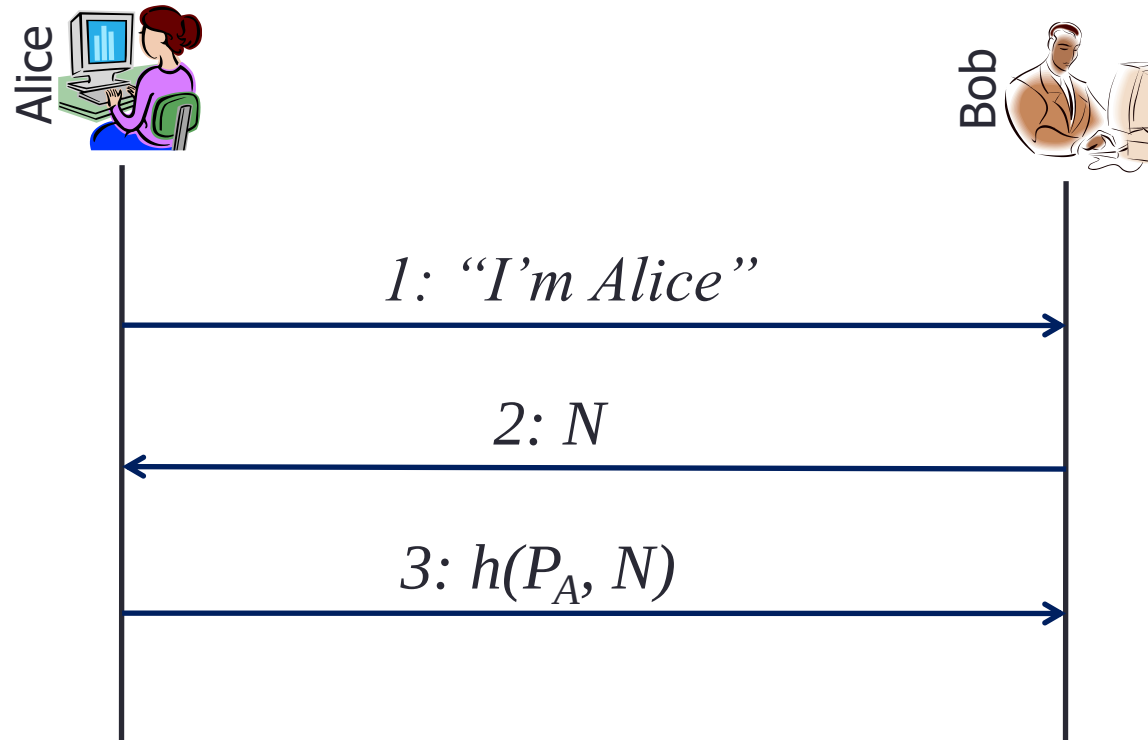


Protocols for Authentication

- ❑ Simple security authentication protocols
- ❑ **Challenge-response authentication protocol**
- ❑ Symmetric keys authentication protocol
- ❑ Public keys authentication protocol
- ❑ Kerberos authentication protocol

Challenge-response authentication protocol

- ❑ N: nonce (number used once)



- ❑ Problem: Bob must know Alice's password.

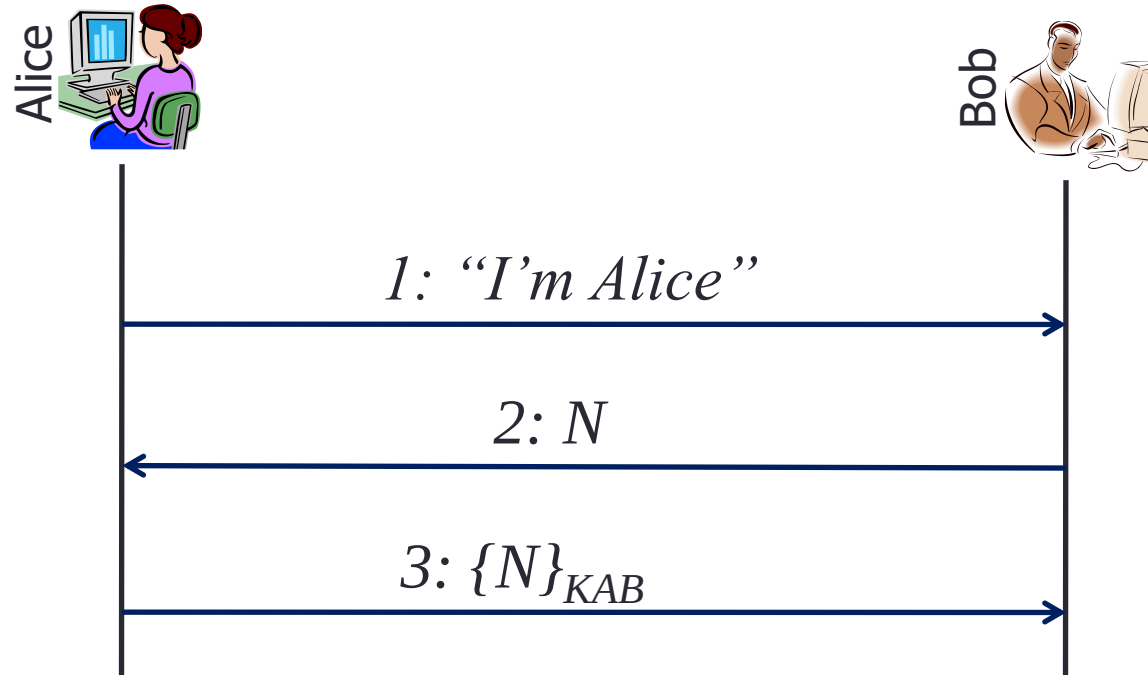
Protocols for Authentication

- ❑ Simple security authentication protocols
- ❑ Challenge-response authentication protocol
- ❑ **Symmetric keys authentication protocol**
- ❑ Public keys authentication protocol
- ❑ Kerberos authentication protocol

Symmetric keys authentication protocol

- ❑ C: ciphertext
- ❑ M: plaintext
- ❑ K_A : key of Alice
- ❑ $C = \{M\}_K$
- ❑ K_{AB} : share symmetric key of Alice and Bob

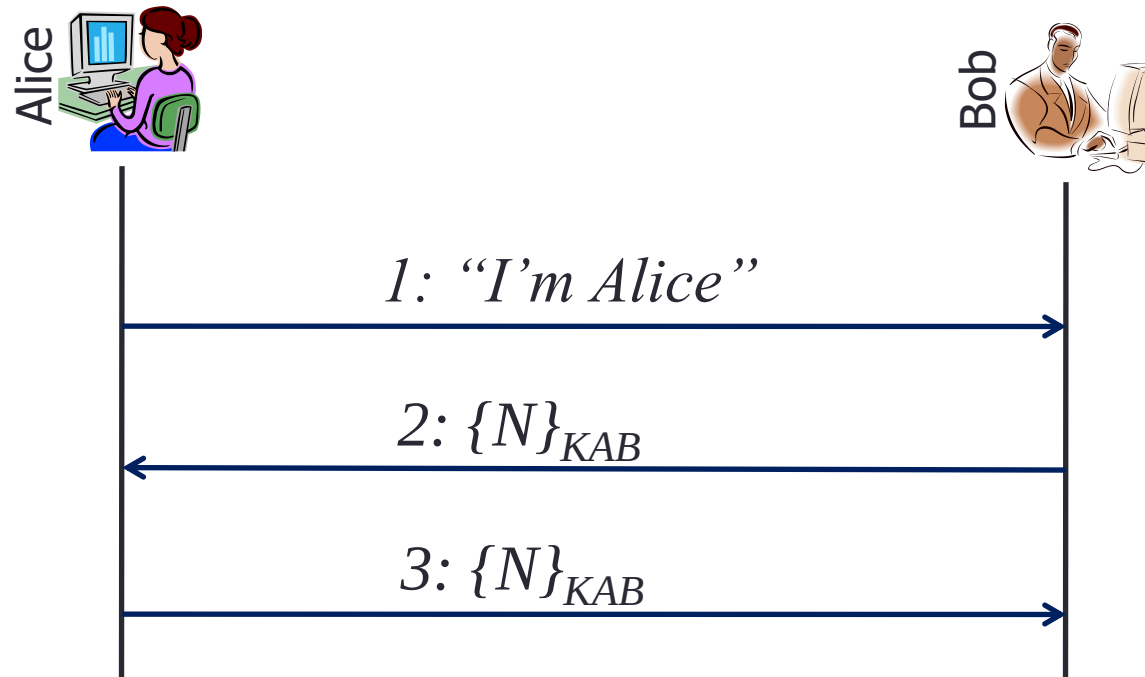
Symmetric keys authentication protocol



- ❑ Problem: Only Bob can authenticate Alice.

Symmetric keys authentication protocol

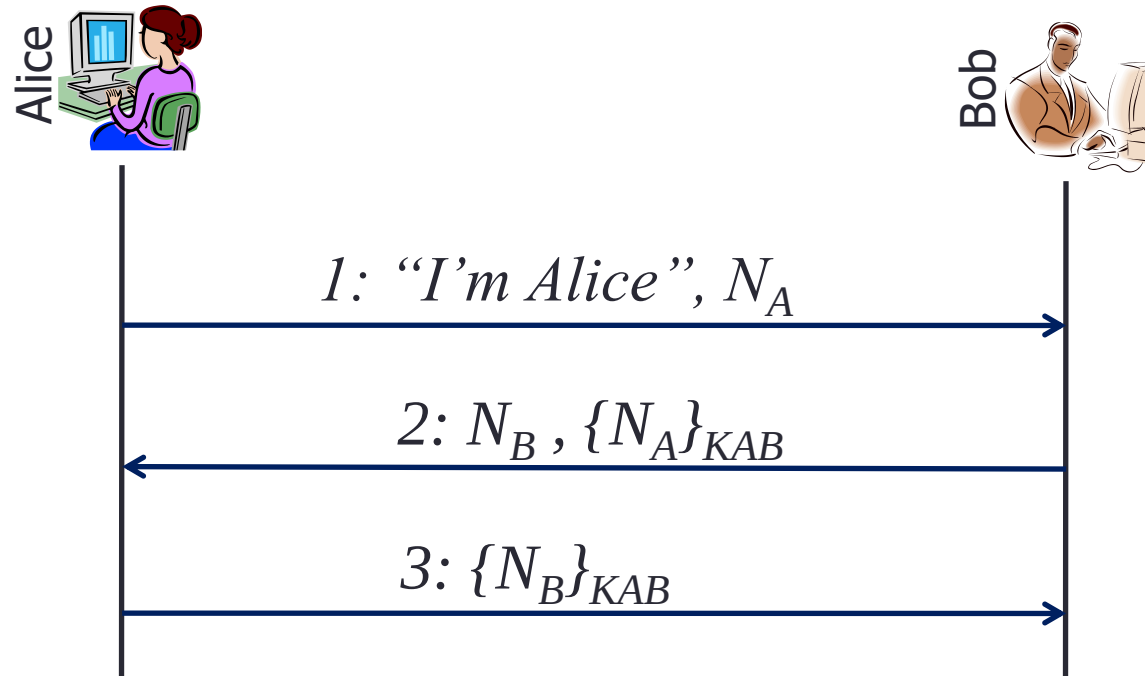
- ❑ Mutual authentication using symmetric keys



- ❑ Problem: The third message in this protocol is simply a replay of the second, and consequently it proves nothing about the sender, be it Alice or Malice.

Symmetric keys authentication protocol

- ❑ Mutual authentication using symmetric keys – fix 1



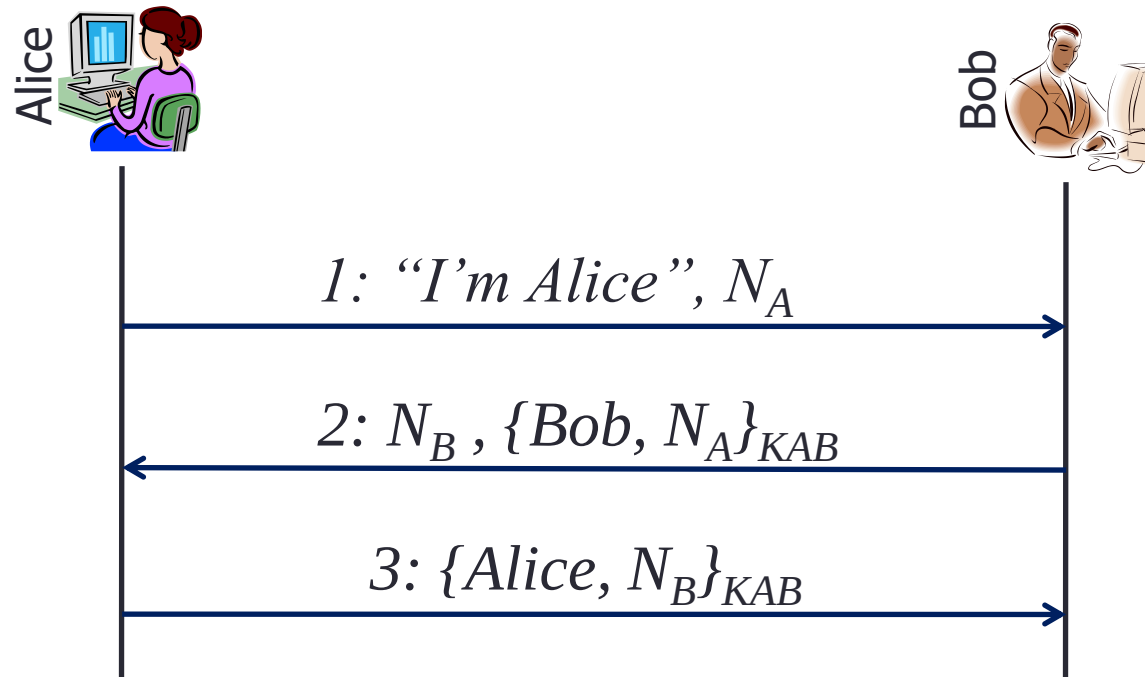
Symmetric keys authentication protocol

- ❑ Mutual authentication using symmetric keys – fix 1 - Attack



Symmetric keys authentication protocol

- ❑ Mutual authentication using symmetric keys – Fix 2



Protocols for Authentication

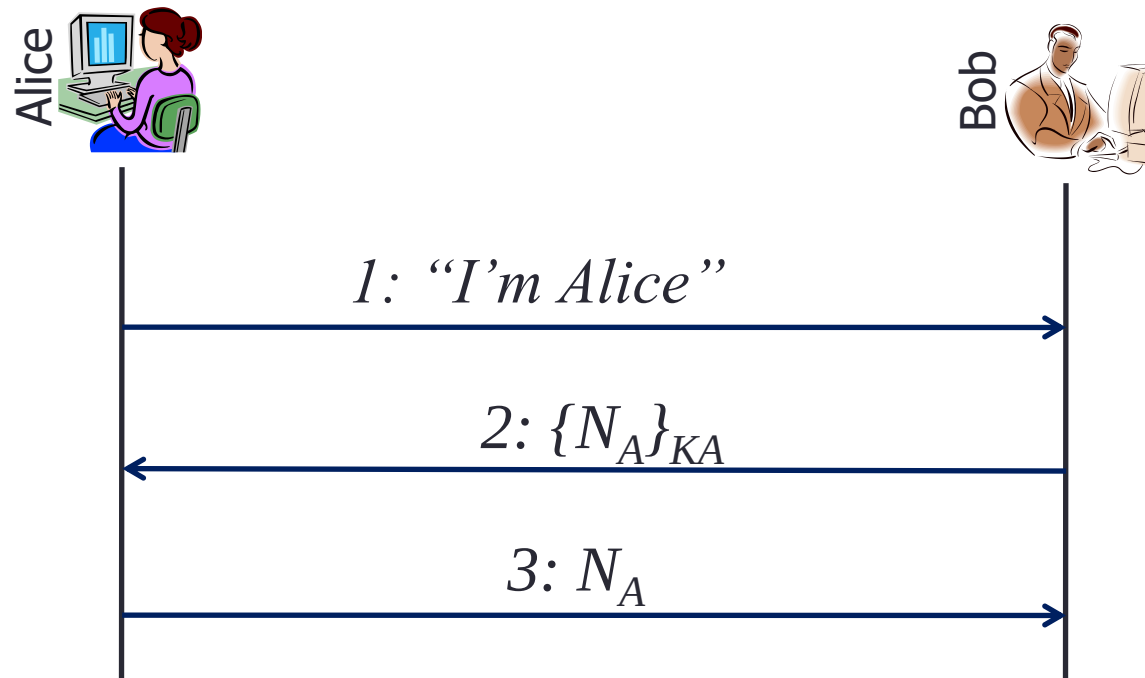
- ❑ Simple security authentication protocols
- ❑ Challenge-response authentication protocol
- ❑ Symmetric keys authentication protocol
- ❑ **Public keys authentication protocol**
- ❑ Kerberos authentication protocol

Public Keys authentication protocol

- ❑ C: ciphertext
- ❑ M: plaintext
- ❑ K_A : public & private keys of Alice
- ❑ $C = \{M\}_{K_A}$: Encrypting a message M with Alice's public key
- ❑ $M = [C]_{K_A}$: decrypt C with Alice's private key
- ❑ $S = [M]_{K_A}$: sign digitally on M Alice's private key
- ❑ $\{\{M\}_{K_A}\}_{K_A} = M$
- ❑ $\{[M]_{K_A}\}_{K_A} = M$

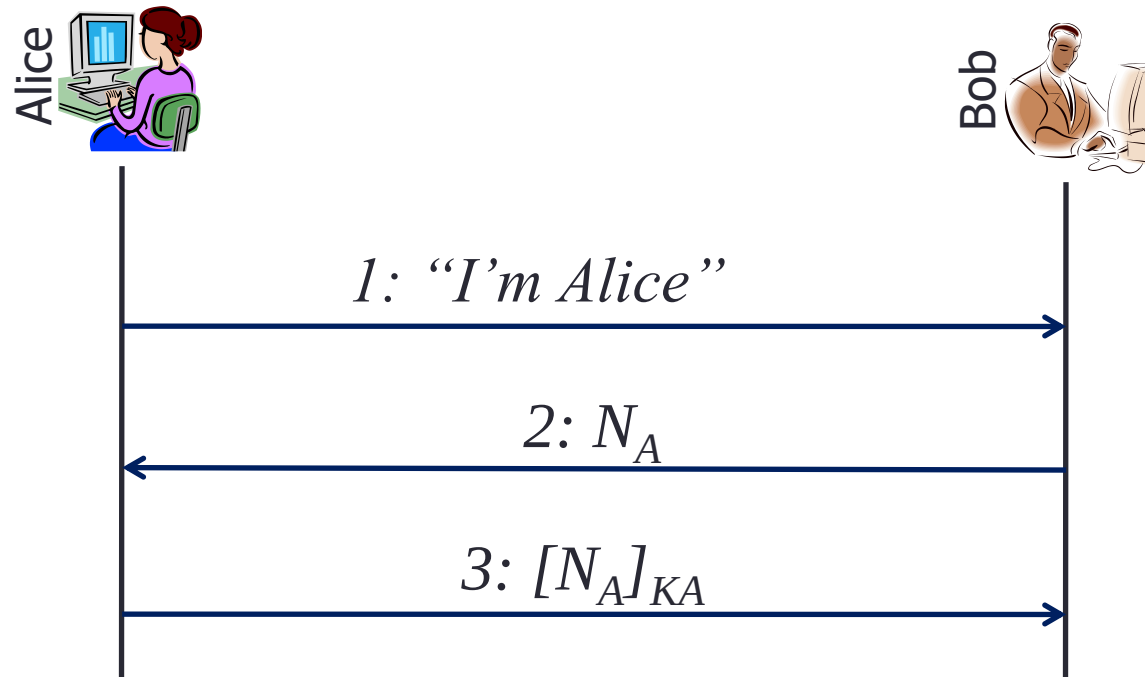
Public Keys authentication protocol

❑ Authentication with Public Key Encryption



Public Keys authentication protocol

❑ Authentication via Digital Signature



Protocols for Authentication

- ❑ Simple security authentication protocols
- ❑ Challenge-response authentication protocol
- ❑ Symmetric keys authentication protocol
- ❑ Public keys authentication protocol
- ❑ **Kerberos authentication protocol**

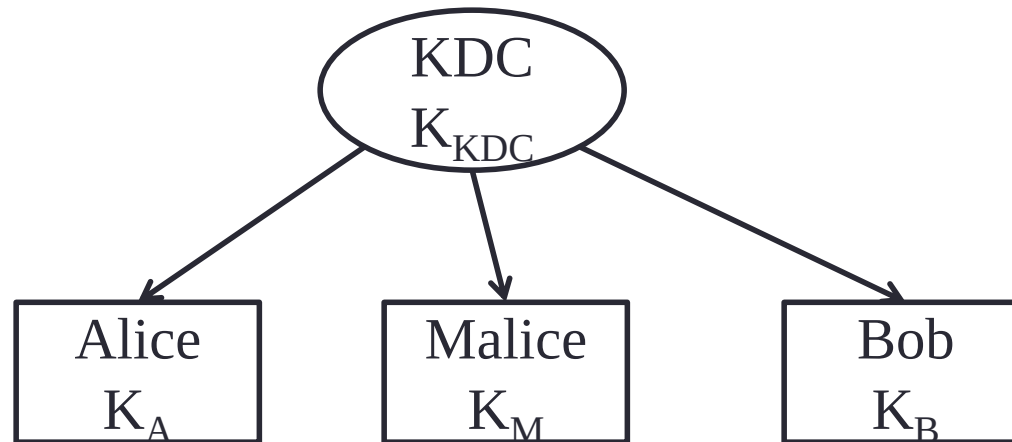
Kerberos authentication protocol

- ❑ Real-world security protocols
- ❑ KERBEROS
 - Using symmetric key cryptography
 - is designed for a smaller scale, such as on a local area network (LAN) or within a corporation
 - Trusted third party: Key Distribution Center - KDC
- ❑ System with N users:
 - Public key: $2N$ keys
 - Symmetric key: N^2 keys
 - Kerberos: N keys

Kerberos authentication protocol

❑ Key Distribution Center KDC

- KDC has a master key K_{KDC} , known only to the KDC
- KDC issues Ticket-Granting Ticket (TGT)
- TGT contains a session key, the user ID of the user to whom the TGT is issued, and an expiration time
- TGT encrypted with the key K_{KDC}
- TGT can only be read by the KDC



Kerberos authentication protocol

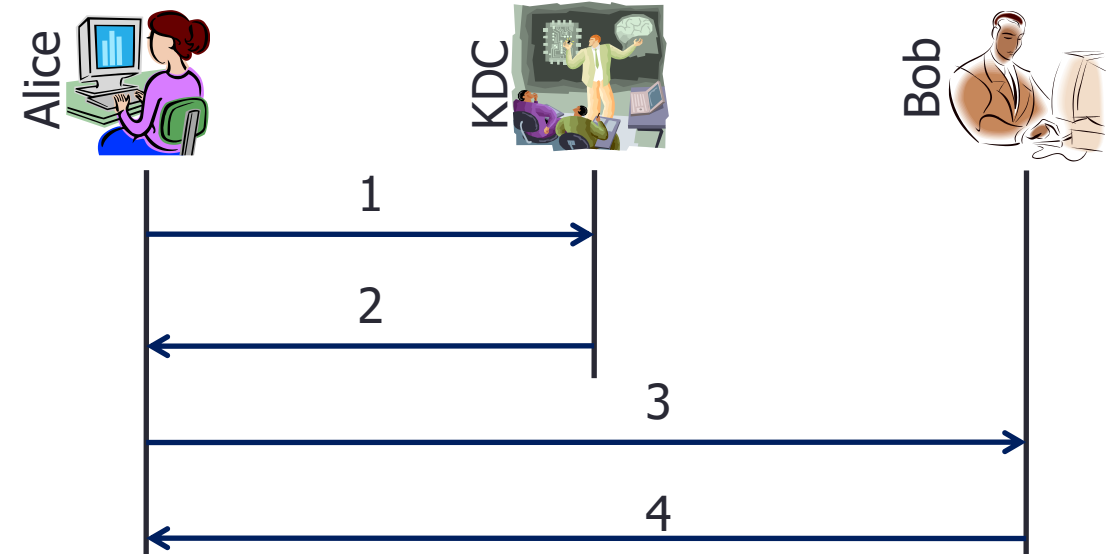
❑ Login:



- ❑ K_A : shared key of Alice and KDC, $K_A = h(\text{password})$
- ❑ S_A : Session key
- ❑ $TGT_A = \{\text{Alice}, S_A\}_{K_{KDC}}$

Kerberos authentication protocol

1. Alice sends to KDC: $Alice, Bob, TGT_A, \{timestamp\}_{SA}$
2. KDC sends to Alice: $\{Bob, K_{AB}, ticket-to-Bob\}_{SA}$
 $ticket-to-Bob: \{Alice, K_{AB}\}_{KB}$
3. Alice sends Bob: $ticket-to-Bob, \{timestamp\}_{KAB}$
4. Bob sends Alice: $\{timestamp + 1\}_{KAB}$



Kerberos authentication protocol

❑ Minor flaw in Kerberos:

- KDC sends Alice: $\{S_A, \textcolor{red}{TGT}_A\}_{K_A}$ where $TGT_A = \{Alice, S_A\}_{K_{KDC}}$
→ KDC sends to Alice: $\{S_A\}_{K_A}, TGT_A$

❑ TGT is encrypted with the key K_{KDC}

→ KDC does not need to know who is making the REQUEST

Homework

- ☐ Secure Shell - SSH
- ☐ Secure Socket Layer - SSL
- ☐ IPSec
- ☐ Wired Equivalent Privacy - WEP

